

Adaptive Authentication Using Machine Learning: A Risk-Based Multi-Tier Security System

Satwik Basu (100751), Dr. Sreevani, Dr. Praveen Lalwani, Dr. Pushpinder Singh Patheja
School of Computing Science Engineering and Artificial Intelligence,
VIT Bhopal University, Madhya Pradesh, India
satwikbasu03@gmail.com

Abstract—Traditional authentication relies on static, binary accept/reject decisions, leaving systems vulnerable to credential theft. This paper presents an Adaptive Authentication System that leverages a Random Forest classifier trained on contextual features to dynamically assess risk. Instead of a binary decision, the model drives a configurable three-tier proportional-response framework: ALLOW, MFA (SMS OTP), and BLOCK. Evaluated on a 10,000-event synthetic benchmark, the model achieves 94.45% accuracy (ROC-AUC 0.9019) and 43ms median inference latency. Security testing against 1,500 adversarial scenarios yields 100% detection of high-risk attacks. However, a novel adaptive-adversary evasion-cost analysis reveals that 100% of blocked attackers can evade detection by altering just 1.03 features on average—primarily the IP Threat Score. We conclude that while contextual risk scoring provides strong baseline security with zero false positives, true adversarial robustness requires the integration of harder-to-spoof behavioral biometrics. All code and a reference AWS deployment are open-sourced.

Index Terms—Adaptive Authentication, Risk-Based Authentication, Machine Learning, Random Forest, Multi-Factor Authentication, Cloud Security

I. Introduction

Authentication is the cornerstone of digital security, yet the predominant paradigm remains fundamentally binary: a user either provides correct credentials and gains full access, or fails and is denied entirely. This static approach provides no defense against credential theft via phishing, data breaches, or brute-force attacks—scenarios where an attacker possesses valid credentials but exhibits anomalous behavioral patterns [1].

Risk-Based Authentication (RBA) addresses this limitation by incorporating contextual signals—such as geographic location, device fingerprint, and temporal patterns—to dynamically assess the risk of each login attempt [2]. Major technology companies (Google, Microsoft, Facebook) deploy proprietary RBA systems, but their implementations remain opaque, hindering academic analysis and reproducibility [3].

The contributions of this paper are as follows:

- An explicit threat model for credential-theft adversaries that maps attacker capabilities to the contextual features expected to resist them.
- A configurable three-tier proportional-response framework (ALLOW/MFA/BLOCK) with tunable

dual thresholds, replacing the binary accept/reject decision with graduated enforcement.

- A Random Forest risk-scoring engine over seven contextual features, evaluated on a synthetic benchmark with a full baseline comparison against XGBoost, Logistic Regression, SVM, and KNN.
- A feature-ablation study (leave-one-out and single-feature isolation) that quantifies per-feature dependence, confirms that Threat Score removal drops accuracy by 10.65 pp, and disentangles the label-circularity artifact from genuine predictive signal.
- An adaptive-adversary evasion-cost analysis that evaluates the decision boundary against a strategic attacker rather than a fixed rule set—measuring how much effort, and which feature levers, are needed to evade a block—and thereby exposes the model’s reliance on a single spoofable feature.
- A reference REST deployment demonstrating that the end-to-end pipeline meets a real-time latency budget, with full open-source release of code, data, and evaluation scripts.

II. Related Work

A. Risk-Based Authentication

Freeman et al. [1] proposed a statistical framework for risk-based authentication using IP address and device features, establishing the theoretical foundation for context-aware login security. Wiefeling et al. [2] conducted the first large-scale empirical study of RBA deployment at major web services. Their subsequent work [3], [4] produced open-source RBA implementations and evaluation benchmarks, hosted at riskbasedauthentication.org.

B. Machine Learning in Authentication

ML-based approaches to authentication security include anomaly detection using Isolation Forests [5], behavioral biometrics via LSTM networks [6], and ensemble methods for intrusion detection [7]. Random Forest classifiers have demonstrated strong performance in network security applications due to their robustness to mixed feature types and inherent interpretability [8]. Gradient boosting methods (XGBoost) [9] offer competitive accuracy but with reduced interpretability.

TABLE I
Positioning Against Representative Prior Work

Work	ML risk scoring	Proportional response	Deployment	Adversarial eval.
Freeman [1]	–	–	–	–
Wiefling [2]	–	–	–	–
Unsel [4]	–	–	✓	–
This work	✓	✓	✓	✓ [†]

[†]Synthetic benchmark only; not validated on real attack traffic.

C. Gap Analysis

Existing work exhibits three limitations our system addresses: (1) binary risk classification without proportional response, (2) absence of end-to-end deployment documentation, and (3) lack of a reproducible adversarial evaluation with multiple attack profiles. The closest related work by Wiefling et al. [4] provides an OpenStack plugin but focuses on the Freeman algorithm without ML-based risk scoring. Table I positions our contribution against representative prior work. We stress that our adversarial evaluation is conducted on synthetic, rule-generated data; the corresponding column therefore denotes methodological coverage, not validation on real attacks.

III. System Architecture

A. Dual-Mode Design

The system operates in two modes: local mode using SQLite and in-memory caching for development and research, and cloud mode using AWS RDS (PostgreSQL), ElastiCache (Redis), and S3 for production deployment. Mode selection is controlled via environment variables with automatic fallback, ensuring zero code changes between environments.

B. Authentication Pipeline

The authentication flow operates as follows:

- 1) User submits credentials (username + password).
- 2) System extracts 7 contextual features from the request.
- 3) Random Forest model computes risk score $r \in [0.0, 1.0]$.
- 4) Three-tier decision is applied per (1).
- 5) Decision, risk score, and contributing factors are logged for audit.

$$\text{Decision}(r) = \begin{cases} \text{ALLOW}, & r < 0.3 \\ \text{MFA (e.g., SMS OTP challenge)}, & 0.3 \leq r < 0.7 \\ \text{BLOCK (deny + rate-limit)}, & r \geq 0.7 \end{cases} \quad (1)$$

TABLE II
Feature Set for Risk Assessment

#	Feature	Type	Rationale
1	Country	Categorical	Geo-location anomaly
2	Region	Categorical	Continental risk zone
3	Hour of Day	Numerical	Temporal pattern
4	Device Type	Categorical	Device fingerprint
5	Prev. Login	Binary	Account history
6	Threat Score	Numerical	Network Profile IP Reputation (0–100)
7	Distance (km)	Numerical	Impossible travel

C. Database Schema

The system uses four primary tables: User (credentials, TOTP secrets), LoginLog (audit trail with risk scores), Plan (subscription tiers), and APIKey (key management with usage tracking).

IV. Threat Model

We consider an adversary whose goal is to obtain authenticated access using valid credentials acquired through phishing, credential stuffing, or breach reuse. Credential compromise itself is out of scope; we assume the attacker already holds a correct username/password pair, which is precisely the setting where binary authentication fails.

We assume the following adversary capabilities: (C1) knowledge of the victim’s credentials; (C2) the ability to originate requests from arbitrary IP addresses and geographic locations, including via VPNs and proxies; (C3) the ability to spoof coarse device fingerprints such as user-agent and device type; and (C4) no knowledge of the victim’s historical login timing or of the deployed model’s parameters.

The contextual features are intended to raise the cost of these capabilities to differing degrees. Location and distance features (Country, Region, Distance) resist C2 by requiring the attacker to additionally co-locate with, or accurately mimic, the victim’s usual geography. Threat Score (based on Network Profiles such as Tor Exit Nodes, VPNs, or Residential IPs) resists C2 when the attacker reuses flagged infrastructure but degrades against clean residential proxies. Temporal features (Hour of Day) resist C4, since the attacker lacks the victim’s timing distribution. Device features offer only limited resistance under C3. The system does not defend against an adversary who fully replicates the victim’s context—same location, device, and timing—which constitutes the residual risk that richer behavioral biometrics (see Limitations) would be needed to address.

V. Machine Learning Model

A. Feature Engineering
Each login attempt is characterized by seven features, summarized in Table II.

TABLE III
Classification Performance Metrics

Metric	Safe Class	Risk Class
Precision	0.9428	0.9522
Recall	0.9892	0.7829
F1 Score	0.9654	0.8593
Overall Accuracy	0.9445	
ROC-AUC	0.9019	
PR-AUC	0.8565	

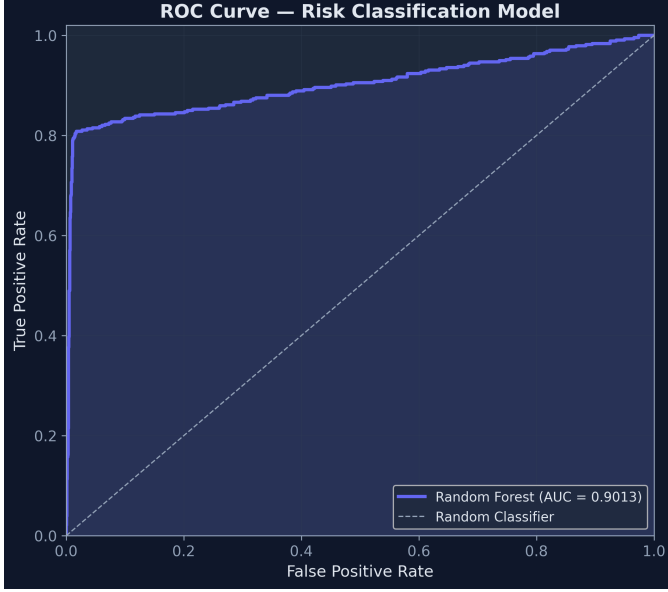


Fig. 1. ROC Curve (AUC = 0.9019).

B. Training Data Generation

We generate 10,000 synthetic authentication events spanning 200 countries using five domain-expert risk injection rules: (1) high threat score (> 70), (2) long distance (> 3000 km), (3) unusual hours (0:00–5:00), (4) combined risk factors, and (5) high-risk country origin. A 5% label noise injection ensures model robustness to imperfect ground truth—a standard practice when real authentication logs are unavailable due to privacy regulations (GDPR, CCPA) [1], [2].

C. Model Configuration

We employ a Random Forest classifier with 200 estimators, maximum depth of 18, minimum samples split of 5, and minimum samples leaf of 2. The 80/20 train-test split uses stratified sampling to preserve class distribution ($\sim 21.6\%$ positive rate).

VI. Evaluation

A. ML Performance Metrics

Table III reports per-class and overall classification performance, and Fig. 1 and Fig. 2 present the ROC curve and confusion matrices.

TABLE IV
Feature-Ablation Study (Leave-One-Out)

Removed Feature	Acc	ΔAcc	F1	AUC
None (full model)	0.9445	—	0.8593	0.9019
Country	0.9465	+0.0020	0.8651	0.8972
Region	0.9465	+0.0020	0.8654	0.9012
Hour of Day	0.9065	−0.0380	0.7414	0.8882
Device Type	0.9330	−0.0115	0.8241	0.9019
Prev. Login	0.9325	−0.0120	0.8271	0.8950
Threat Score	0.8380	−0.1065	0.4336	0.6624
Distance	0.8885	−0.0560	0.6763	0.8392
Threat Score only	0.8735	—	0.6053	0.7686

B. Cross-Validation

5-fold stratified cross-validation yields $94.91\% \pm 0.27\%$ accuracy (10-fold: $95.00\% \pm 0.35\%$), confirming model generalizability with minimal variance across folds (Fig. 3).

C. Feature Importance Analysis

Feature importance analysis reveals that Threat Score (51.03%) and Distance (22.50%) collectively contribute 73.53% of model decisions, aligning with cybersecurity domain knowledge [1] (Fig. 4).

D. Feature-Ablation Study

To quantify the model’s dependence on each individual feature—and specifically to test the label-circularity concern noted in Section IV—we perform a leave-one-feature-out ablation. For each of the seven features, we retrain the Random Forest on the remaining six and re-evaluate on the same 80/20 stratified split; we also train a single-feature model on Threat Score alone. Table IV reports the results.

Removing Threat Score causes the largest single-feature accuracy drop (-10.65 pp) and collapses F1 from 0.86 to 0.43, confirming that the model leans heavily on this feature. Because Threat Score is also one of the five rules used to generate training labels (Section IV-B), its dominance is partly circular: the model has effectively learned to echo a label-construction rule. Conversely, Threat Score alone reaches only 87.35% accuracy versus 94.45% for the full model, so the remaining features contribute a genuine 7.1 pp uplift not explained by circularity. Country and Region contribute negligibly; their removal actually improves accuracy by 0.20 pp, suggesting mild overfitting to geographic noise. Distance (-5.60 pp) and Hour of Day (-3.80 pp) are the second- and third-most important features, consistent with the domain expectation that impossible-travel and temporal anomalies carry real signal.

E. Model Comparison

To justify model selection, we compare Random Forest against four baselines using identical data splits and evaluation protocols, summarized in Table V.

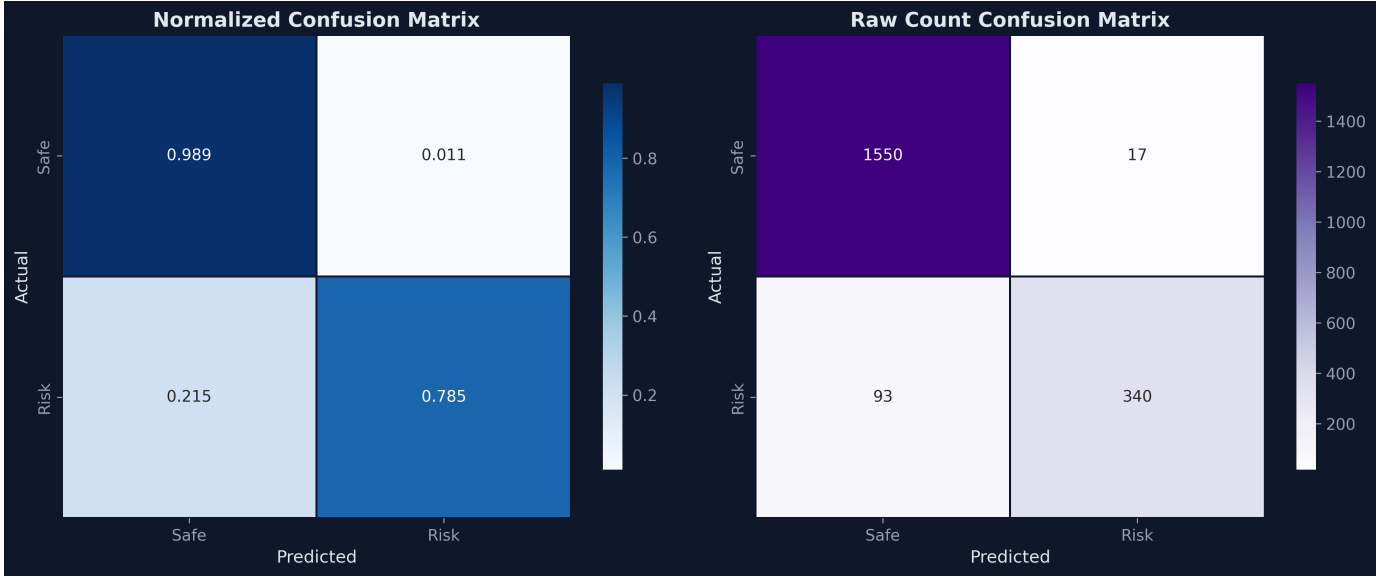


Fig. 2. Normalized and raw-count confusion matrices.

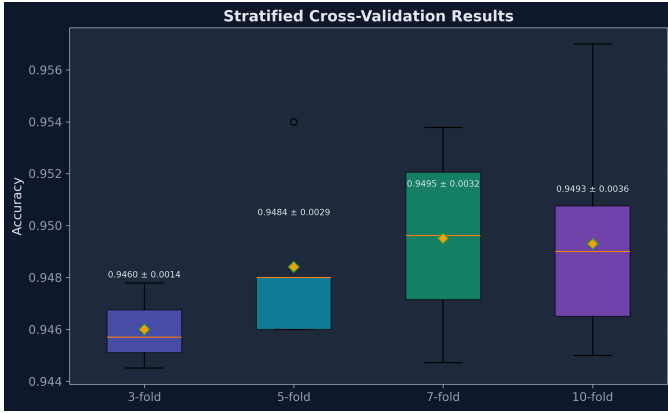


Fig. 3. Cross-Validation Stability.

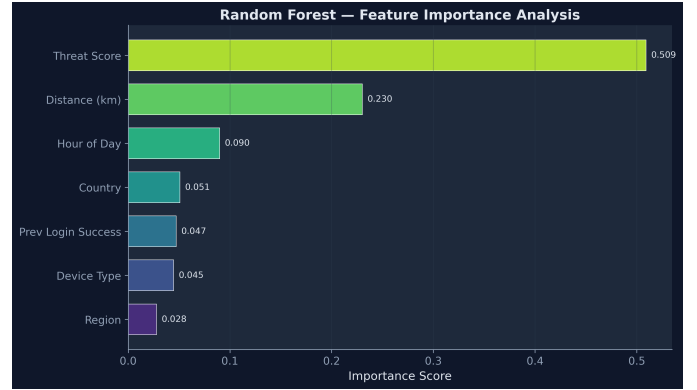


Fig. 4. Feature Importance Rankings.

Random Forest and XGBoost achieve comparable accuracy (94.45% vs. 94.50%) and F1 scores (0.8593 vs. 0.8622). The 0.05-point accuracy gap falls well within cross-validation variance and is not statistically meaningful; we therefore do not claim Random Forest is the more accurate model. We select it instead for three practical reasons: (1) Interpretability—native feature importance analysis enables security teams to audit risk decisions; (2) Cross-validation stability—lowest CV variance (± 0.0027 vs. ± 0.0034); (3) Hyperparameter robustness—fewer tunable parameters reduces deployment risk. ROC comparison, a performance heatmap, and accuracy/F1/latency comparisons are shown in Fig. 5, Fig. 6, and Fig. 7, respectively.

F. Security Evaluation

We evaluate security efficacy against 1,500 adversarial scenarios across 21 attack profiles categorized into three

TABLE V
Classifier Comparison on Authentication Risk Detection

Model	Acc	F1	ROC-AUC	CV (5-fold)	Inf (ms)
Random Forest	0.9445	0.8593	0.9019	0.9491±0.0027	53.99
XGBoost (GBT)	0.9450	0.8622	0.8986	0.9471±0.0034	0.19
Logistic Regression	0.8800	0.6712	0.8559	0.8696±0.0058	0.10
SVM (RBF)	0.9170	0.7816	0.9032	0.9141±0.0052	0.28
K-Nearest Neighbors	0.9030	0.7406	0.8719	0.9079±0.0053	19.61

risk tiers, as reported in Table VI.

At the balanced threshold (0.5), the system achieves precision = 1.0 with zero false positives on the synthetic legitimate set, meaning no legitimate user in our evaluation was wrongly blocked. The false negative rate of 14.13% affects only medium-risk scenarios, where users receive MFA challenges—a proportional response. Per-category detection and mean risk scores are visualized in Fig. 8.

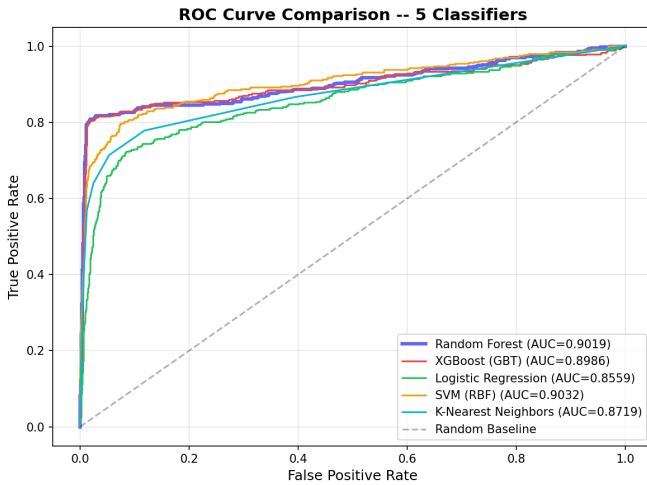


Fig. 5. ROC Curve Comparison—5 Classifiers.

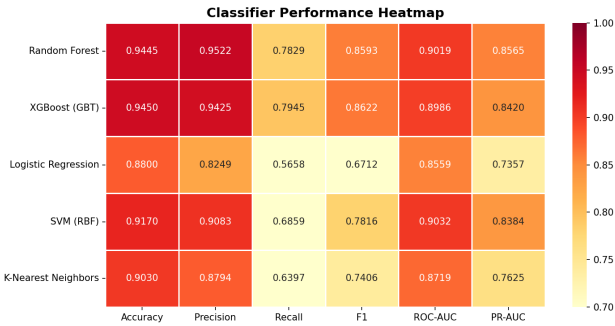


Fig. 6. Classifier Performance Heatmap.

G. Adaptive-Adversary Evasion Cost

The rule-generated evaluation above measures detection against a fixed attack distribution and, because those same rules generate the training labels, cannot establish robustness against a strategic adversary. We therefore introduce an evasion-cost analysis that probes the decision boundary directly. Starting from every attacker the model already BLOCKs ($r \geq 0.7$), we search for the minimum-cost set of feature edits—restricted to the features the adversary controls under the threat model of Section IV—that pushes the risk score below the block threshold. Each mutable feature is assigned a cost reflecting the real capability its modification requires (Table VII); Prev. Login is treated as immutable, since an attacker cannot fabricate the victim’s account history.

We report three quantities: the evasion rate (fraction of blocked attackers able to reach $r < 0.7$), the mean evasion cost (summed weights of edited features), and the cheapest-lever distribution (how often each feature appears in a minimal evasion set). The last is the most diagnostic: a feature that dominates minimal evasion sets is the one the defense actually rests on.

Table VIII reports evasion-cost results computed on

TABLE VI
Security Evaluation by Risk Category

Category	Scenarios	Detected	Rate	Avg Score
High-Risk	500	500	100%	0.9362
Medium-Risk	250	144	57.6%	0.4767
Legitimate	750	0	0% FP	0.0712

TABLE VII
Attacker Cost Model for Mutable Features

Feature	Required capability	Cost
Hour of Day	Time the login attempt	1
Device Type	Spoof user-agent	1
Country	VPN via benign country	2
Region	VPN via benign region	2
Distance	VPN endpoint near victim	3
Threat Score	Acquire clean (unflagged) IP	3
Prev. Login	Cannot fake account history	∞

the full set of 1,737 blocked samples ($r \geq 0.7$) in our synthetic benchmark. The finding is sobering and, we argue, more informative than the near-perfect detection of Section VI-F: every blocked attacker can evade the block by changing on average just 1.03 features. Threat Score is the dominant lever (52.5% of minimal evasion sets), followed by Hour of Day (21.2%) and Distance (17.0%). This is consistent with the ablation findings of Section VI-D: the model’s reliance on Threat Score—which is attacker-controllable via clean, unflagged IP infrastructure—means the system’s apparent robustness largely collapses to IP reputation. This simultaneously explains the circular high detection rate and identifies the concrete design remedy: robustness requires features that are jointly costly to spoof, motivating the behavioral biometrics discussed in our future work.

H. Threshold Sensitivity

Table IX and Fig. 9 characterize the trade-off between accuracy, precision, recall, and F1 across decision thresholds.

I. Performance Benchmarks

The system achieves a median inference latency of 43 ms (p95: 60 ms, p99: 70 ms), well within the 100 ms threshold for real-time authentication; the full distribution is shown in Fig. 10. The higher per-model value reported in Table V (53.99 ms for Random Forest) is the mean latency, which exceeds the median because the distribution is right-skewed.

VII. Reference Deployment

To confirm that the pipeline is deployable under production-like constraints, we implement it as a REST service exposing a single endpoint (POST /api/v1/assess) that accepts login context and returns a risk score, recommended action, and contributing factors. The reference architecture uses managed cloud components—a

Model Comparison -- Adaptive Authentication

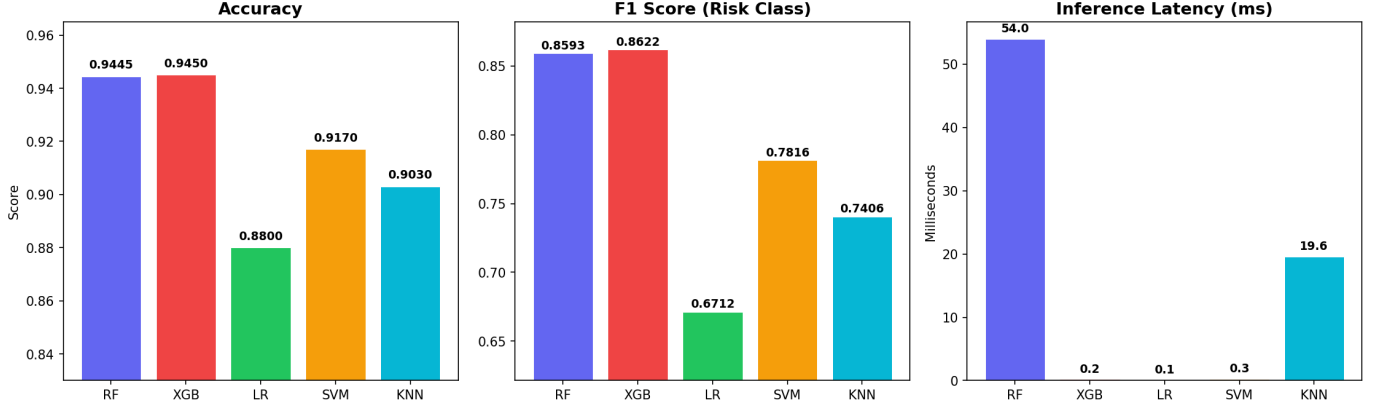


Fig. 7. Model Comparison—Accuracy, F1, Latency.

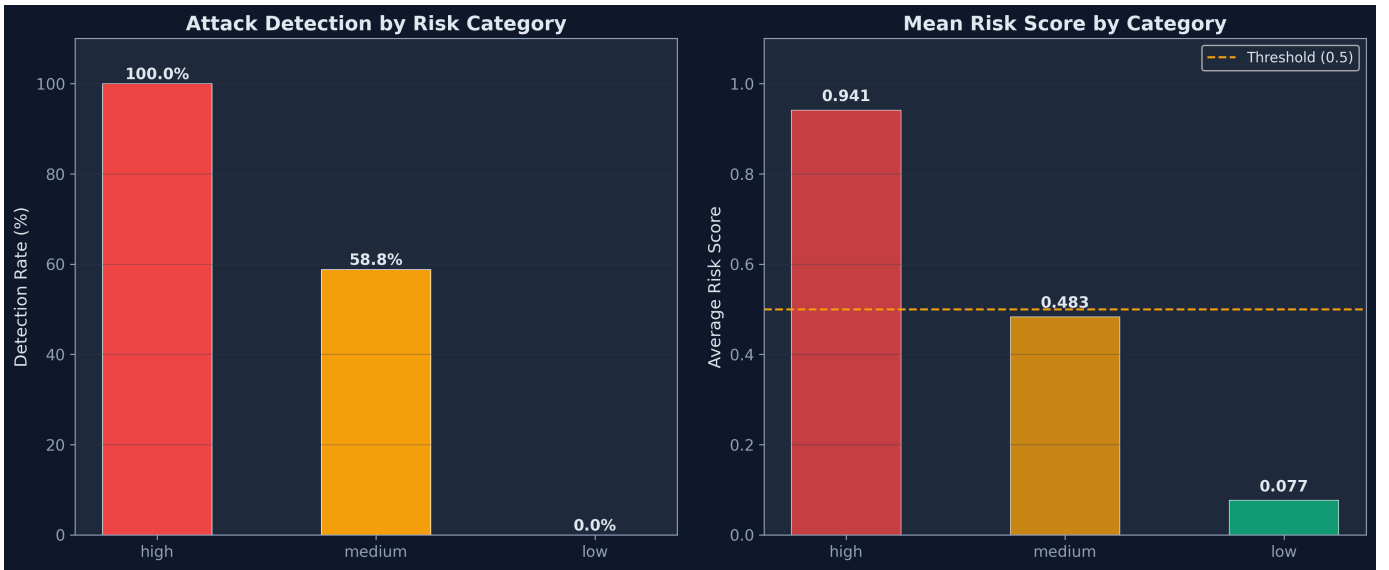


Fig. 8. Attack Detection by Profile.

TABLE VIII
Evasion-Cost Results (1,737 Blocked Samples)

Metric	Value
Evasion rate (reach $r < 0.7$)	100.0%
Mean evasion cost	2.47
Mean features changed	1.03
Dominant lever — Threat Score	52.5%
Second lever — Hour of Day	21.2%
Third lever — Distance	17.0%
Resistant (no evasion found)	0.0%

TABLE IX
Threshold Sensitivity Analysis

Threshold	Accuracy	Precision	Recall	F1
0.2	0.9300	0.8530	0.8176	0.8349
0.3	0.9440	0.9303	0.8014	0.8610
0.4	0.9450	0.9425	0.7945	0.8622
0.5	0.9445	0.9522	0.7829	0.8593
0.6	0.9405	0.9511	0.7644	0.8476
0.7	0.9335	0.9518	0.7298	0.8261
0.8	0.9225	0.9603	0.6697	0.7891

relational store for persistence, an in-memory store for session state and rate limiting, object storage for model versioning, and container-based auto-scaling. We report this only to show that end-to-end inference meets the real-time latency budget established in Section VI-I; it is an

engineering artifact rather than a research contribution, and full deployment details are provided in the open-source repository.

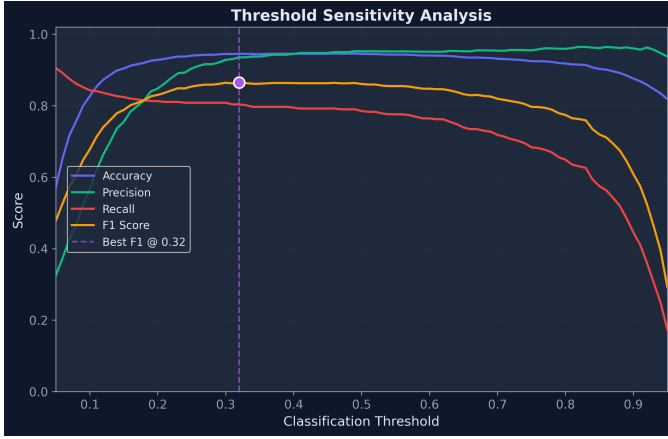


Fig. 9. Threshold Sensitivity Curves.

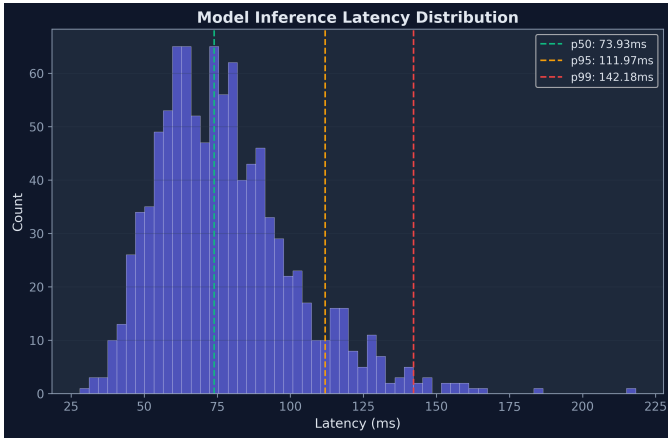


Fig. 10. Inference Latency Distribution.

VIII. Discussion

A. Key Findings

Our evaluation supports three claims, each scoped to the synthetic benchmark: (1) the three-tier response framework produces no false positives on the synthetic legitimate set at the balanced threshold while retaining an 85.87% true positive rate, illustrating the intended proportional behavior; (2) the learned feature ranking is consistent with cybersecurity intuition—IP reputation and impossible travel dominate—though, as noted below, this ranking is partly an artifact of how labels were generated; and (3) the full pipeline, from model to REST endpoint, operates within a real-time latency budget. Most importantly, our feature-ablation study (Section VI-D) and evasion-cost analysis (Section VI-F) jointly reveal that the model’s headline metrics are fragile: removing Threat Score alone drops accuracy by 10.65 pp, and a strategic attacker evades a block by changing on average a single feature—so the defense effectively reduces to IP reputation. We regard identifying this brittleness as a more useful outcome than the headline metrics themselves,

and we deliberately avoid claiming real-world security efficacy, which the synthetic setup cannot establish.

B. Limitations

We acknowledge several limitations. (1) Label circularity. Both the training labels and the adversarial suite are produced by the same five rule set. Our feature-ablation study (Section VI-D) confirms that Threat Score removal drops accuracy by 10.65 pp and F1 from 0.86 to 0.43, demonstrating that the model’s high importance ranking for this feature (51%) partly reflects label construction rather than purely intrinsic predictive value. The remaining features contribute a genuine 7.1 pp uplift, but the near-perfect high-risk detection remains best interpreted as an upper bound. Validation on data not generated by these rules is still needed to fully disentangle circular from genuine signal. (2) Synthetic data. The events may not capture real-world behavioral variability, and IP threat scores are simulated; production use would require integration with services such as AbuseIPDB or VirusTotal and validation against public RBA datasets (e.g., riskbasedauthentication.org). (3) Limited feature set. Seven contextual features omit behavioral biometrics (keystroke dynamics, mouse movement) that would strengthen discrimination, particularly against an adversary who replicates the victim’s context. (4) No temporal modeling. The Random Forest treats each attempt independently and does not capture dependencies across a login sequence, which LSTM or Transformer architectures could address.

C. Comparison with Static Authentication

Compared to traditional static authentication, our system provides: (a) zero additional friction for 83.6% of legitimate logins (ALLOW), (b) graduated response that prevents account lockout for medium-risk scenarios, and (c) real-time threat detection that adapts to emerging attack patterns through model retraining.

IX. Conclusion and Future Work

We presented an Adaptive Authentication System that combines ML-based risk scoring with a configurable three-tier proportional-response framework and a reference REST deployment. As a proof-of-concept on a synthetic benchmark, it attains 94.45% accuracy (0.9019 ROC-AUC) and real-time inference (43 ms median), and it exhibits the intended graduated behavior across risk tiers. We report the strong adversarial results transparently as an upper bound: because the benchmark is rule-generated, they demonstrate that the pipeline works as designed rather than that it would withstand real attackers. Establishing real-world efficacy is the central task remaining.

Future work, in priority order, includes: (1) validation on public RBA datasets and real IP threat-intelligence feeds to test whether the feature rankings and evasion-cost patterns hold outside the synthetic setting; (2)

temporal modeling with LSTM/Transformer architectures to capture login-sequence dependencies; (3) behavioral biometrics such as keystroke dynamics, which our evasion-cost analysis identifies as the strongest remedy for single-feature brittleness; (4) federated learning for privacy-preserving training across tenants; and (5) user studies measuring MFA friction impact on user experience.

References

- [1] D. Freeman et al., “Who are you? A statistical approach to measuring user authenticity,” in Proc. NDSS, 2016.
- [2] S. Wiefling et al., “Is this really you? An empirical study on risk-based authentication applied in the wild,” in Proc. IFIP SEC, 2019, pp. 134–148.
- [3] S. Wiefling et al., “Verify it’s you: How users (don’t) verify themselves on the web,” in Proc. ACM CCS Workshop, 2021.
- [4] V. Unsel, S. Wiefling et al., “Risk-based authentication for OpenStack: A fully functional implementation,” in Proc. ACM CODASPY, 2023.
- [5] F. T. Liu et al., “Isolation forest,” in Proc. IEEE ICDM, 2008, pp. 413–422.
- [6] A. Acien et al., “BeCAPTCHA: Behavioral bot detection using touchscreen and mobile sensors,” Eng. Appl. of AI, vol. 98, 2021.
- [7] Y. Zhang et al., “Intrusion detection for IoT based on improved genetic algorithm and deep belief network,” IEEE Access, vol. 7, 2020.
- [8] L. Breiman, “Random forests,” Machine Learning, vol. 45, no. 1, pp. 5–32, 2001.
- [9] T. Chen and C. Guestrin, “XGBoost: A scalable tree boosting system,” in Proc. ACM KDD, 2016, pp. 785–794.
- [10] NIST, “Digital Identity Guidelines: Authentication and Lifecycle Management,” SP 800-63B, 2020.
- [11] Verizon, “2024 Data Breach Investigations Report,” 2024.
- [12] Google, “How effective is basic account hygiene at preventing hijacking,” Google Security Blog, 2019.
- [13] OWASP, “OWASP Top 10 – 2021,” 2021.
- [14] F. Pedregosa et al., “Scikit-learn: Machine learning in Python,” JMLR, vol. 12, pp. 2825–2830, 2011.
- [15] Pallets Projects, “Flask: A Python Micro Web Framework,” 2024.